

Del caos de logs al control total

Un agente de IA a tu medida

Hugo Avila - Pentester & Software Developer

```
sshd[2214]: Failed password for demo
sshd[2214]: Failed password for demo
kernel: IN=eth0 SRC=172.18.0.1 DPT=2222
sca: CIS 5.2.4 failed
sca: CIS 1.1.7 failed
sshd[2214]: Failed password for demo
sca: CIS 4.1.3 failed
sshd[2214]: Failed password for demo
```

rule 5763 · level 10

github.com/hugok2k · hugoavila.dev

— QUIÉN HABLA

HugoAvila

Cybersecurity Consultant & Software Developer

Como desarrollador y consultor en ArtsSec, combino la ingeniería de software con proyectos de investigación

linkedin

[linkedin.com/in/devhugoavila](https://www.linkedin.com/in/devhugoavila)

github

github.com/hugok2k

web

hugoavila.dev

Un SOC no tiene falta de datos. Tiene sobra de datos.

SSH, firewall, IDS, aplicaciones, miles de eventos por segundo. El ojo humano no escala, y una regla de correlación sola tampoco alcanza para separar el ruido de lo que realmente importa.

Qué es Wazuh



XDR + SIEM unificado

Plataforma gratuita y de código abierto, sin licencias ni vendor lock-in



Agente por endpoint

Malware, integridad de archivos (FIM), compliance y vulnerabilidades, directo en el equipo

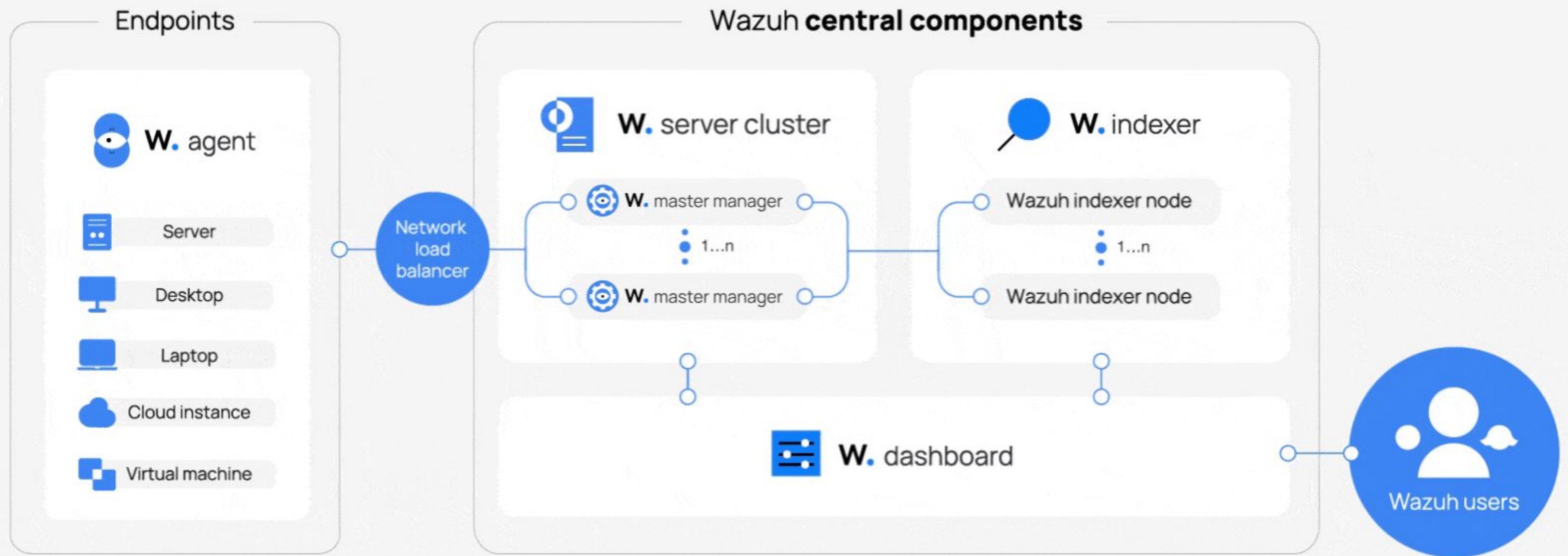


Reglas y niveles

Cada evento dispara reglas que le asignan un nivel de 0 a 16, de ruido a crítico

Hoy protege más de 15 millones de endpoints en el mundo, con más de 100 mil empresas usándolo en producción.

01 - WAZUH



Cómo está armado por dentro



Un evento crudo no es una alerta: recién se convierte en una cuando el manager le aplica una regla y le asigna un nivel.

Qué es Hermes



Agente con ejecución

No es solo un chat, corre código, shell y herramientas dentro de un sandbox propio



Cron nativo

Tareas programadas propias del agente



Integrado a Telegram

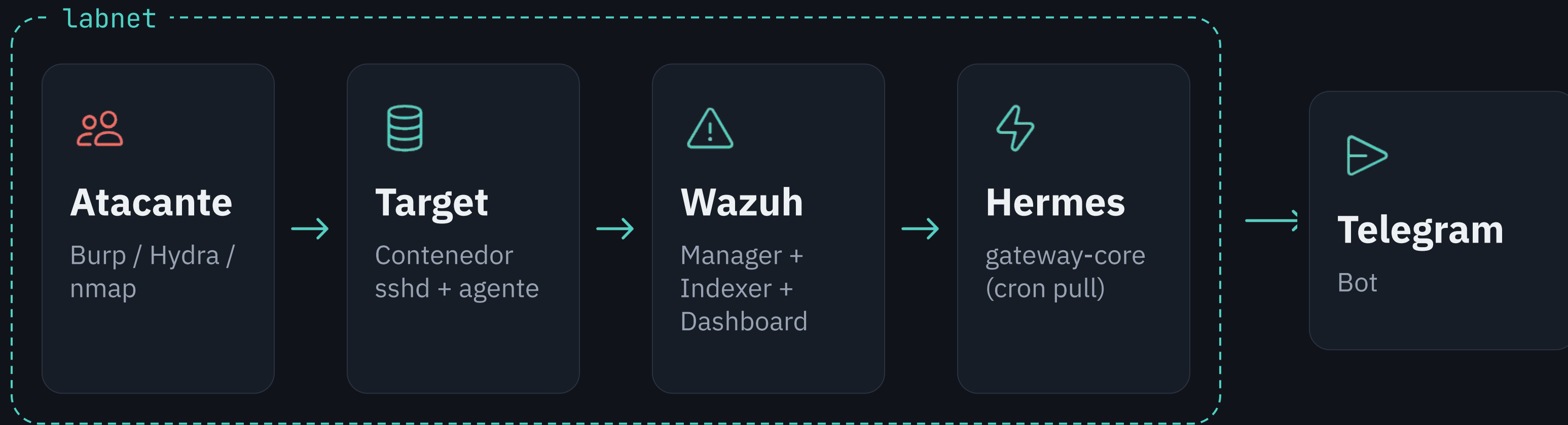
Hablas y recibís avisos con contexto

Hermes es un harness de código abierto: no es un modelo, es la capa que envuelve a un LLM y le da memoria, herramientas y la posibilidad de ejecutar acciones reales, no solo responder texto.

Wazuh genera el dato. Hermes decide si te importa.

El volumen es el verdadero enemigo: cientos de hallazgos de compliance tapan la única alerta que sí importa. La IA no reemplaza el criterio de seguridad, lo aplica a escala, sobre datos que un humano no llega a leer.

Todo en una sola red de Docker



Hermes también consulta a OpenCode (LLM) por HTTP para interpretar

Todo vive en la misma red interna labnet. Nada sale a internet salvo Hermes hablando con OpenCode y Telegram.

Un solo docker-compose.yml

- ✓ Corre en **cualquier máquina**
- ✓ 100% reproducible
- ✓ El agente de Wazuh
- ✓ Repo público para replicarlo

```
~/lab-hermes-wazuh
├─ docker-compose.yml
├─ config/ certs y config de Wazuh
├─ target/ Dockerfile del endpoint
└─ hermes/ config, cron, scripts

$ sudo docker compose up -d
```

Así se hablan Wazuh y Hermes



El cron vive **adentro de Hermes** , no en el sistema operativo, sin depender de ningún proceso externo ni de configurar nada por fuera del agente.

Qué es ruido y qué es señal

Ruido se descarta

- ✓ Hallazgos de compliance / SCA (hardening CIS de baseline)
- ✓ Eventos por debajo del nivel mínimo configurado
- ✓ Alertas ya vistas (marcador de última corrida)

Señal se avisa

- ⚠ Múltiples intentos fallidos de SSH del mismo origen
- ⚠ Escaneos de puertos
- ⚠ Modificación de archivos críticos (FIM)

Si algo sobrevive al filtro, recién ahí se llama a la IA por HTTP para redactar el resumen - con un resumen determinístico como respaldo si esa llamada falla.

Generemos el caos

```
# fuerza bruta SSH real
```

```
hydra -l demo -P rockyou.txt ssh://127.0.0.1:2222
```

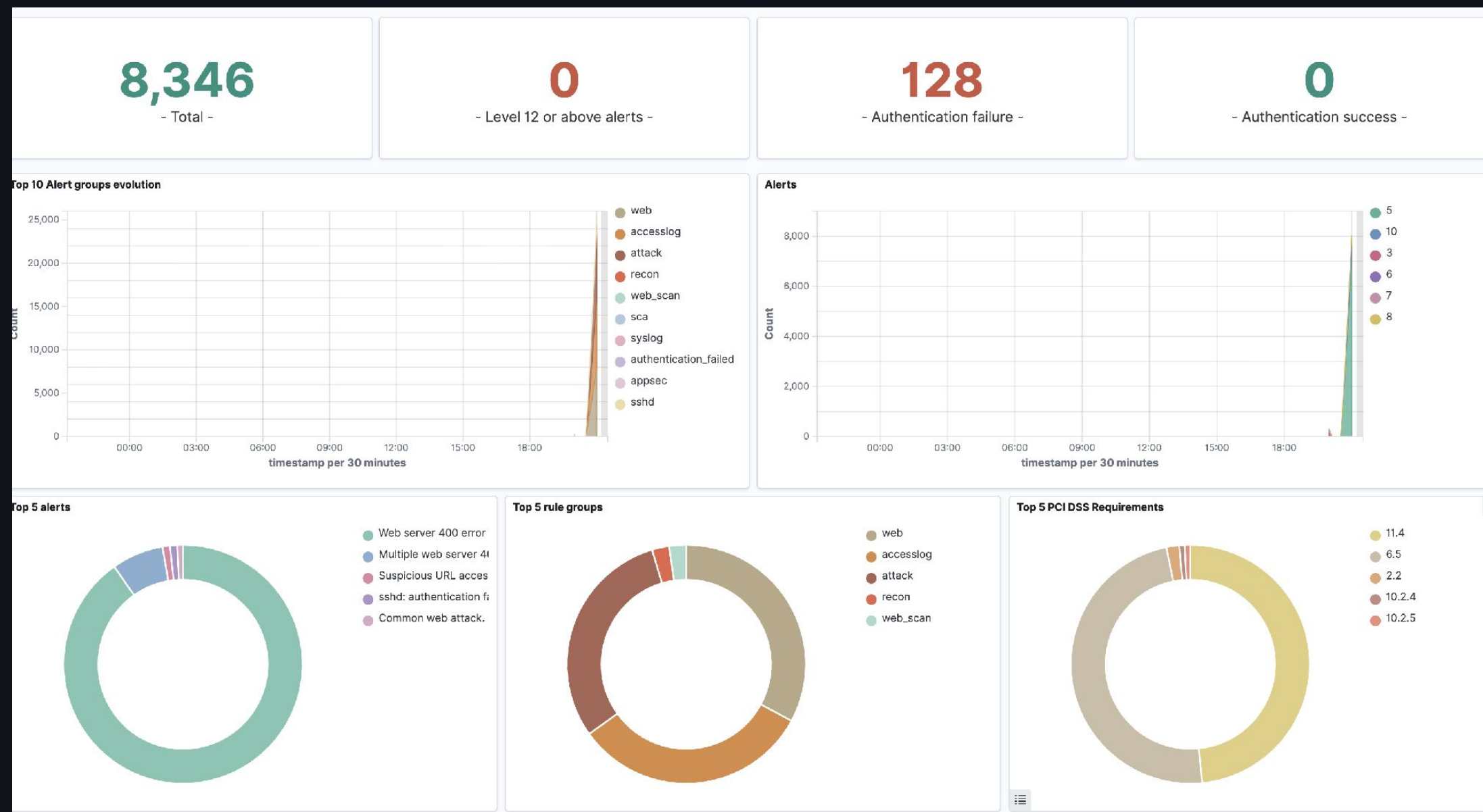
```
# escaneo de servicios
```

```
nmap -sV -p 2222 127.0.0.1
```

Lo que ve Wazuh



Threat Hunting · Dashboard



Lo que ve Wazuh

o0o Threat Hunting · Events

W.

Rules

Rules (4,513)
From here you can manage your rules.

Search

ID ↑	Description
1	Generic template for all syslog rules.
2	Generic template for all firewall rules.
3	Generic template for all ids rules.
4	Generic template for all web rules.
5	Generic template for all web proxy rules.
6	Generic template for all windows rules.
7	Generic template for all wazuh rules.
200	Grouping of wazuh rules.
201	Agent event queue rule
202	Agent event queue is level full.

Rows per page: 10 ▾

API1513629884013a

Multiple web server 400 error codes from same source ip.

View alerts of this Rule

MITRE TECHNIQUESVulnerability Scanning

MITRE TACTICSReconnaissance

Related rules

ID ↑	Description	Groups	Compliance	Level	File
31100	Access log messages grouped.	web, accesslog		0	0245-web_rules.xml
31101	Web server 400 error code.	attack, web, accesslog	PCI_DSSGDPRNIST_800_53TSC	5	0245-web_rules.xml
31102	Ignored extensions on 400 error codes.	web, accesslog		0	0245-web_rules.xml
31103	SQL injection attempt.	attack, sql_injection, web, accesslog	PCI_DSSGDPRNIST_800_53TSCMITRE	7	0245-web_rules.xml
31104	Common web attack.	attack, web, accesslog	PCI_DSSGDPRNIST_800_53TSCMITRE	6	0245-web_rules.xml
31105	XSS (Cross Site Scripting) attempt.	attack, web, accesslog	PCI_DSSGDPRNIST_800_53TSCMITRE	6	0245-web_rules.xml
31106	A web attack returned code 200 (success).	attack, web, accesslog	PCI_DSSGDPRNIST_800_53TSCMITRE	6	0245-web_rules.xml
31107	Ignored URLs for the web attacks	web, accesslog		0	0245-web_rules.xml
31108	Ignored URLs (simple queries).	web, accesslog		0	0245-web_rules.xml
31109	MSSQL Injection attempt (/ur.php, urchin.js)	attack, web, accesslog	PCI_DSSGDPRNIST_800_53TSCMITRE	6	0245-web_rules.xml

Rows per page: 10 ▾< 1 2 3 4 >

Lo que recibís

Un mensaje en Telegram, en párrafos cortos: qué pasó, contexto si suma, y una recomendación concreta.

Silencio total si no hay nada interesante, es el comportamiento esperado, no un fallo.



Hermes Lab



Fuerza bruta de SSH contra target-endpoint, múltiples intentos de login fallidos desde el mismo origen.

Un escaneo automatizado contra el sitio web del mismo host (XSS, SQLi, paneles admin expuestos), reconocimiento previo

Recomendación: bloquear el origen y revisar si hubo un login exitoso.

— POR QUÉ VALE LA PENA

No reemplaza al analista. **Le devuelve el tiempo.**



Menos fatiga de alertas

El ruido de compliance ya no tapa la alerta que sí importa



Reacción más rápida

Te enterás en tu chat, sin tener que abrir el dashboard cada rato



Cobertura sin un SOC

Un freelance o un equipo chico cubre lo que antes pedía guardia 24/7

Y el patrón no es exclusivo de Wazuh: dato + filtro determinístico + IA para interpretar sirve para cualquier otra fuente de logs que genere más volumen del que un humano puede leer.

Todo el laboratorio, **en un repo público**

github.com/hugok2k



docker-compose.yml, Dockerfiles, scripts



Documentación paso a paso, con los errores incluidos



Base reusable - para otra charla o, con autorización, un cliente real

Gracias. ¿Preguntas?